

Cloud Compliance & Governance Controls

Framework Mapping & Compliance Checklist, Gap Analysis & Remediation, Azure Management Groups & Azure Policy, Mandatory Tagging, and Automated Compliance Checking with Documented Enforcement Evidence

Scenario organization: Horizon Valley Medical Center (HVMC)

Capstone project: AccessGuard Health — Microsoft Entra ID & Azure IAM Operations

Rubric item: Cloud Compliance & Governance Controls (Cloud Security 1)

Cloud platform: Microsoft Azure (Resource Group `HVMC-CloudSecurity-RG`)

Framework mapped: HIPAA Security Rule, crosswalked to NIST CSF 2.0 via NIST SP 800-66r2

Builds on: the Compliance Auditing Basics, Documentation & Reporting, and Legal & Ethical Implementation submissions for this same Azure IAM environment

Report date: October 7, 2026

Created by: Sabitha S Karanavar

This submission is prepared as a classroom lab exercise for the HVMC simulation used in this capstone. Framework citations are to real, current authority (HIPAA/NIST); Azure configuration states, gap findings, and enforcement evidence are illustrative/simulated against the lab's Azure subscription and do not describe a live production tenant.

Rubric Cross-Reference

Rubric Requirement	Where Addressed
Map cloud configurations to one major compliance framework (CIS Benchmarks, NIST, or HIPAA/PCI DSS), creating a compliance checklist with gap analysis and remediation plans	Section 1 — Compliance Framework Mapping & Checklist; Section 2 — Gap Analysis & Remediation Plan
Configure account-level governance (AWS Organizations/SCP equivalent) with preventive guardrails and mandatory resource tagging	Section 3 — Governance Implementation (Azure Management Groups & Azure Policy)
Implement automated compliance checking (AWS Config Rules equivalent) with documented evidence of policy enforcement	Section 4 — Automated Compliance Checking & Documented Evidence

Platform note: this rubric item names AWS-specific services (AWS Organizations, Service Control Policies, AWS Config Rules). HVMC's actual lab environment for this capstone is built on **Microsoft Azure** (see the Architecture Design submission and the real [HVMC-CloudSecurity-RG](#) resource group). This document satisfies the same governance requirements using Azure's native equivalents — **Management Groups** in place of Organizations/OUs, **Azure Policy** (deny-effect definitions) in place of Service Control Policies, and **Azure Policy compliance evaluation** in place of AWS Config Rules, since Azure Policy combines preventive (deny) and detective (compliance-scan) enforcement in a single service rather than splitting them across two.

This submission reuses the same HIPAA Security Rule Technical Safeguards scope audited in the companion *HVMC_Compliance_Auditing_Basics.pdf* (Unique User Identification, Audit Controls, Login/Logout & Session Termination) and carries its two open findings — the orphaned Azure identity/account and the missing log-retention configuration — forward into this document's gap analysis, so the governance controls built here (Azure Policy, tagging, compliance evaluation) are shown closing the same gaps that audit identified, not a disconnected set of new ones.

1. Compliance Framework Mapping & Checklist

1.1 Framework Selected

Of the frameworks this rubric permits (CIS Benchmarks, NIST, or HIPAA/PCI DSS), this submission maps HVMC's Azure configuration to the **HIPAA Security Rule (45 CFR §164.312)**, the same framework already used for this IAM environment's audit and legal-compliance work, and crosswalks each requirement to its corresponding **NIST CSF 2.0** subcategory using the official **NIST SP 800-66r2** HIPAA-to-CSF crosswalk. This keeps one consistent framework across the whole compliance submission set while still satisfying the rubric's NIST-mapping expectation.

1.2 Cloud Compliance Checklist

Framework Requirement	HIPAA Citation	NIST CSF 2.0	Azure Configuration	Status
Unique identification for every user	§164.312(a)(2)(i)	PR.AA-05	Individually-owned Microsoft Entra ID accounts and role-assignable Azure RBAC roles	MET (1 exception — see 2.1)
Audit controls / access logging	§164.312(b)	PR.PT-01, DE.AE-03	Azure Activity Log, Diagnostic Settings → Log Analytics, Microsoft Defender for Cloud	PARTIAL — logging on, retention not configured
Access control / minimum necessary	§164.312(a)(1)	PR.AA-05	Least-privilege Azure RBAC role assignments, tag-based scoping	MET
Risk management / preventive guardrails at the account level	§164.308(a)(1)(ii)(A)	GV.PO-01, PR.AA-05	Azure Management Groups + Azure Policy (deny-effect definitions)	GAP — not yet configured
Information system inventory & accountability	§164.308(a)(8)	ID.AM-01, ID.AM-02	Mandatory resource tagging via Azure Policy	GAP — not yet enforced
Regular review of system activity	§164.308(a)(1)(ii)(D)	DE.CM-01, DE.CM-06	Azure Policy compliance evaluation (automated compliance checking)	GAP — not yet deployed

2. Gap Analysis & Remediation Plan

2.1 Gap Analysis

Gap	Required State	Current State	Risk	Status
No account-wide preventive guardrails	High-risk actions (disabling logging, creating unapproved regions/resources) blocked tenant-wide via policy	No Azure Management Group hierarchy or Azure Policy assignments in place	HIGH	New — addressed in Section 3
No mandatory tagging	Every resource tagged with owner, environment, and data classification at creation time	Tagging is optional and inconsistently applied	MEDIUM	New — addressed in Section 3
No automated compliance checking	Continuous, automated evaluation of resource configuration against the framework above	Compliance checks are manual and point-in-time (e.g., this audit series)	HIGH	New — addressed in Section 4
Orphaned Azure identity (carried forward)	Every account mapped to one accountable individual	1 legacy account with no owner on file (Compliance Auditing Basics, Control 1)	MEDIUM	In progress — now also flagged automatically (Section 4.2)
No log-retention policy (carried forward)	Access logs retained 6 years per HIPAA documentation standard	Logging enabled, retention unconfigured (Compliance Auditing Basics, Control 2)	HIGH	In progress — now also flagged automatically (Section 4.2)

2.2 Remediation Plan

Priority	Recommendation	Owner (acting role)	Target
1	Stand up an Azure Management Group hierarchy with Azure Policy assignments blocking the highest-risk actions tenant-wide	IAM/Identity Administrator	Within 15 days
2	Deploy Azure Policy definitions for continuous compliance checking, starting with the checklist items above	IAM/Identity Administrator	Within 20 days

3	Enforce mandatory resource tagging via the built-in "Require a tag" Azure Policy definitions	IAM/Identity Administrator	Within 20 days
4	Resolve the carried-forward orphaned-account and log-retention findings using the automated detection this governance layer now provides	IAM/Identity Administrator	Within 30 days (per existing remediation tracker)

3. Governance Implementation

3.1 Azure Management Group & Resource Scope Structure

HVMC's lab subscription currently hosts a single production-style environment scoped to the `HVMC-CloudSecurity-RG` resource group (the real resource group holding `HVMC-Prod-VNet`, its subnets, NSGs, load balancer, NAT gateway, and `HVMC-Bastion`). The governance design below is scoped today at that resource group, with the full Management Group hierarchy documented as the target structure once this subscription is one of several under HVMC's tenant:

Scope	Purpose
Tenant Root Management Group	Root of the hierarchy; used only for billing and top-level Azure Policy/RBAC administration, not workloads
Security Management Group	Houses the centralized logging/audit resources (Log Analytics workspace, Microsoft Defender for Cloud plan administration)
Production-Workloads Management Group	HVMC's production Azure subscription and resource groups (including <code>HVMC-CloudSecurity-RG</code>) in scope for this audit series
Sandbox Management Group	Lab/experimentation subscriptions, held to a looser policy set so they don't block coursework iteration

3.2 Azure Policy Definitions (Service Control Policy Equivalent)

Azure Policy	Purpose	Effect	Applied To
Deny-Disable-Diagnostic-Settings	Blocks deleting or disabling the Diagnostic Settings that send Activity Log and resource logs to Log Analytics — the controls this entire audit series depends on	Deny	Production-Workloads Management Group
Require-MFA-For-Privileged-Roles	Blocks sign-in for Owner/Contributor-assigned accounts without an active MFA session (enforced via Microsoft Entra Conditional Access, paired with Azure Policy for reporting)	Deny (conditional)	Production-Workloads Management Group / Entra ID tenant
Deny-Public-Blob-Access	Blocks any Storage Account configuration that allows anonymous/public blob access	Deny	Production-Workloads Management Group

Require-Resource-Tags	Blocks creation of VM, Storage, or role-assignment resources missing the mandatory tag set (Section 3.3)	Deny (conditional)	Production-Workloads Management Group
Restrict-Regions	Blocks resource creation outside the approved Azure region (East US) for HVMC's data residency needs	Deny	Production-Workloads Management Group

Example — the `Require-Resource-Tags` Azure Policy definition, enforced with a `deny` effect against missing tag fields:

```
{
  "properties": {
    "displayName": "Require Environment, Owner, and DataClassification tags",
    "mode": "Indexed",
    "policyRule": {
      "if": {
        "anyOf": [
          { "field": "tags['Environment']", "exists": "false" },
          { "field": "tags['Owner']", "exists": "false" },
          { "field": "tags['DataClassification']", "exists": "false" }
        ]
      },
      "then": { "effect": "deny" }
    }
  }
}
```

3.3 Mandatory Resource Tagging

Tag Key	Purpose	Example Value
Environment	Distinguishes production from sandbox/test resources for policy scoping	production
DataClassification	Flags resources that store or process ePHI so they inherit the strictest controls	ephi
Owner	Names the accountable individual or role — directly closes the orphaned-account gap by making ownership a creation-time requirement, not an after-the-fact audit finding	iam-admin
CostCenter	Supports the program's existing budget-tracking needs	hvmc-capstone

Enforcement is two-layered: the **Require-Resource-Tags** Azure Policy definition blocks untagged resource creation at the Resource Manager level with a **deny** effect (preventive), and the same policy definition's ongoing compliance scan in Section 4 continuously re-checks already-existing resources for drift (detective) — together satisfying both a preventive and a detective control for the same requirement from a single Azure Policy assignment, which is itself a documented practice under NIST CSF's PR (Protect) and DE (Detect) function pairing.

4. Automated Compliance Checking & Documented Evidence of Enforcement

4.1 Azure Policy Definitions Deployed for Continuous Compliance Checking

Azure Policy (built-in)	Type	Checks For	Remediation Action
"MFA should be enabled on accounts with owner permissions on your subscription"	Built-in (Defender for Cloud)	Every privileged Entra ID account has MFA enabled	Notify IAM/Identity Administrator; account flagged until resolved
"Azure Monitor should collect activity logs from all regions" / Diagnostic Settings audit	Built-in	Activity Log is exported to Log Analytics tenant/subscription-wide	Alert Security Management Group; Azure Policy already blocks disabling the diagnostic setting (defense in depth)
"Secure transfer to storage accounts should be enabled" / infrastructure encryption	Built-in	All Storage Accounts enforce encryption at rest and in transit	Auto-remediation via a <code>deployIfNotExists</code> policy applies the required setting
Require-Resource-Tags (custom)	Custom (deny + audit)	Environment, DataClassification, and Owner tags present on in-scope resource types	Non-compliant resources surfaced on the Azure Policy compliance dashboard for owner assignment
"Guest/stale accounts with elevated permissions should be reviewed" (Entra ID access reviews)	Built-in (Defender for Cloud / Entra ID)	Accounts with credentials unused beyond a defined age threshold	Flags for deprovisioning review — this is the check that would have caught the orphaned account automatically
"Management ports should be closed on your virtual machines"	Built-in (Defender for Cloud)	NSGs do not allow unrestricted inbound management ports (SSH/RDP) from the internet	Auto-remediation tightens the offending NSG inbound rule

4.2 Documented Evidence of Policy Enforcement

The entries below are the evidence log this rubric item asks for — each row ties a deployed control back to an observed enforcement event, including the two findings carried forward from the Compliance Auditing Basics audit:

Control / Policy	Enforcement Mechanism	Evidence Captured	Result
Require-MFA-For-Privileged-Roles	Preventive — sign-in-time	Azure AD sign-in log showing an <code>AccessDenied</code> interrupt	BLOCKED

(Conditional Access + Policy)	Conditional Access block	on a privileged role sign-in attempted without an active MFA session	
Entra ID stale-account review	Detective — scheduled access review	Access review report shows the legacy account from Control 1 (Compliance Auditing Basics) flagged as <code>non-compliant / unreviewed</code> on first evaluation	NON-COMPLIANT → under remediation
Diagnostic Settings / log retention policy	Detective — scheduled Azure Policy compliance scan	Policy compliance state confirms Diagnostic Settings are <code>Compliant</code> for "export enabled," with a linked note that retention configuration (Control 2 finding) remains open and is tracked separately	PARTIALLY COMPLIANT
Require-Resource-Tags	Preventive (deny) + Detective (compliance scan)	Azure Policy compliance dashboard count of untagged resources dropped to zero after the policy assignment went into effect; zero new untagged resources created since	COMPLIANT
Deny-Public-Blob-Access	Preventive — Resource Manager deny	Activity Log event showing a denied storage account update attempting to set <code>allowBlobPublicAccess = true</code>	BLOCKED
Storage encryption/secure transfer policy	Detective with auto-remediation	Policy compliance history showing one storage account flagged <code>Non-compliant</code> , then <code>Compliant</code> after the <code>deployIfNotExists</code> remediation task ran	AUTO-REMEDIED

4.3 Ongoing Monitoring

These Azure Policy compliance events and Conditional Access denial events feed the same KPI dashboard and quarterly compliance status report built in the Documentation & Reporting submission — the "log retention configured and verified" and "open remediation findings" KPIs there are now populated automatically from this governance layer rather than requiring a manual audit pass each quarter.

Sources: *HVMC_Compliance_Auditing_Basics.pdf* (companion audit); NIST SP 800-66r2, *Implementing the HIPAA Security Rule: A Cybersecurity Resource Guide*; HHS Office for Civil Rights, 45 CFR §164.308/.312; Microsoft Learn, *Azure Policy* and *Microsoft Defender for Cloud* documentation. Prepared as the *Cloud Compliance & Governance Controls* deliverable for the Semester 4 Healthcare IAM Operations Home Lab capstone.